



RISK MANAGEMENT Specification

Table of Contents

Abstract:	3
Introduction	3
Cyber Threat Intelligence and Incident Response	3
a. Incident Details	3
1. Victim organization details:	3
2. Details of incident:	4
b. Incident Analysis	4
1. Access Vector:	4
2. Incident Indicators:	4
3. Known vulnerability exploited:	5
4. Evidence collected:	5
5. Incident duration:	5
6. Estimated Impact of the incident:	5
c. Courses of Action	6
d. Lessons Learned	6
Automated Vulnerability Scanning and Analysis	6
Asset register:	12
Threat Analysis Model using DREAD Framework:	13
Threat Analysis Table:	14
Risk register:	16
Explanation:	16
Risk Heatmap:	19
Risk Control and Mitigation Actions:	19
Cyber Security Framework Control Categories (NIST CSF)	20
Graphical Summary of Control Categories and Subcategories	21
Security Training and Awareness Program Outline:	21
1. Objectives:	21
2. Target Audience:	21
3. Topics to be Addressed:	21
4. Training Techniques and Delivery:	21
5. Documentation and Feedback:	22
6. Evidence of Learning:	22

7. National and Local Policy Integration:	22
8. Continuous Improvement Strategies:	22
References:	23

Table of Contents

Figure 1 Nmap port scan.....	7
Figure 2 Nmap Scripting.....	8
Figure 3 Nessus Configuration	9
Figure 4 Nessus Scan.....	9
Figure 5 Nessus Report	10
Figure 6 NVD Analyst	11
Figure 7 Metasploit Exploit	12
Figure 8 Risk Heatmap (made on word)	19



Rhysida Ransomware Group Targets King Edward VII's Hospital in London

Abstract:

The release of confidential medical records by the Rycida ransomware organization at King Edward VII Hospital has caused global concern. This case highlights the need for strong cybersecurity measures and the growing threat as ransomware attacks against critical organizations. Effectively countering targeted attacks and strengthening cybersecurity defenses requires a comprehensive strategy to prevent the exploitation of vulnerabilities and compromise confidentiality. This paper investigates the hack, analyzes issues, analyzes their implications, and makes recommendations for the prompt development of cybersecurity measures in the healthcare sector.

Introduction

The recent Rhysida ransomware breach at King Edward VII Hospital raised global concerns about the vulnerability of stolen data, including medical reports, X-rays, prescriptions, and employee data. The story highlights the growing threat of ransomware attacks plaguing critical organizations. CVE-2020-1472 exposes targeted exploitation vulnerabilities, such as those that can be used to compromise networks and extract confidential information.

The updated CISA Known Exploited Vulnerabilities Catalog identified 184 CVEs associated with ransomware attacks, with Microsoft products being the most targeted, posing the greatest risk to enterprises. Such ease of exploitation, as built into the CISA report, enhanced cybersecurity measures to protect against ransomware attacks, patches - It also shows the urgent need for management systems.

A joint cybersecurity advisory (CSA) from the FBI and CISA warned of the wide-ranging impact of the Rhysida ransomware, highlighting the team's strategy, which included ransomware-as-a-service (RaaS) services and ground-survival techniques for malicious actors.

This comprehensive report examines the specifics of the King Edward VII Hospital breach, examines the implications, response options, and wider implications for the healthcare sector, and highlights the critical importance of computerization, proactive security measures taken to prevent such heinous attacks.

Cyber Threat Intelligence and Incident Response

a. Incident Details

1. Victim organization details:

King Edward VII Hospital, a leading central London private healthcare provider with a distinguished history of treating members of the royal family. This independent charity hospital carries a proud Royal Protection heritage and rich history since 1899. The institute blends world-leading medical expertise, embodying a compassionate culture known for its strong commitment,

the hospital provides a comfortable and supportive environment, ensuring that patients have minimal disruption to their day day life on their journey of recovery. Notably, King Edward VII Hospital operates as a charity driven by the spirit of philanthropy. Generous donations have allowed the hospital to lead the way in medical advancements, enabling it to provide high quality care to its patients. Additionally, this almshouse is dedicated to providing highly subsidized care to veterans of The Armed Forces, underscoring the organization's commitment to serving the wider community.

2. Details of incident:

- **Date incident occurred:** 30th November 2023
- **Date incident discovered:** 27th November 2023
- **Incident Summary:** The Rhysida ransomware group breached King Edward VII Hospital policy and gained unauthorized access to sensitive medical information including x-rays, medical reports, prescriptions and registration forms
- **Involvement of Personal identifiable information:** The Royal Family's preferred healthcare provider highlighted an IT security incident at the hospital in which confidential medical information was accessed by a third party, prompting an investigation by GCHQ's National Cyber Security Center (NCSC) and the police. While medical information about members of the Royal family is reportedly kept separate and remains unaffected, less than 1% of patients at the hospital are affected, and it gives concerns about possible misuse of information
- **Type of personal identifiable information affected:** The breach affected a small portion of the hospital's patient database, potentially exposing sensitive medical information, although information about members of the Royal family was reportedly isolated and not affected by the breach.
- **Type of systems compromised:** The breach targeted the hospital's core IT systems, which contain sensitive medical records, and prompted an extensive investigation by cybersecurity officials.
- **Type of data compromised:** Internet access denied access to vital medical records including X-rays, medical reports, prescriptions and registration forms, however, it was found that information about the medical affairs of the royal family were unaffected.

b. Incident Analysis

1. Access Vector:

The Rhysida ransomware group likely gained unauthorized entry into the hospital's systems by exploiting vulnerabilities present within the IT infrastructure. This could have been accomplished through multiple avenues, including exploiting weaknesses in external-facing services or conducting targeted phishing campaigns directed at the hospital's staff. As the investigation is still in process the vulnerabilities in target IT system are not disclosed publically.

2. Incident Indicators:

After the breach, Rhysida publicly showcased stolen medical records on the dark web, accompanying this act with a demand for ransom in exchange for the compromised data. The group further threatened to release this information if their demands were not met.

3. Known vulnerability exploited:

While specifics about the exact vulnerabilities exploited within the hospital's IT systems were not disclosed in the public report, the Rhysida group managed to exploit certain weaknesses to gain illicit access. However from the blog [2] we came to this information that, The Rhysida ransomware group employs multifaceted strategies to breach target networks, capitalizing on specific vulnerabilities and employing sophisticated methodologies:

- I. Remote external facing services: The group gains leading access by providing vulnerable external facing services such as Virtual Private Networks (VPNs) and Remote Desktop Protocols (RDPs) that exploit vulnerabilities in these services allow access to target networks.
- II. Compromised credentials: Typically, the Rhysida Group uses compromised credentials to penetrate networks, using stolen or vulnerable authentication information to gain unauthorized access to critical systems and data on the importance of
- III. Survival methods on the ground: Using native or in-built operating system tools and utilities the Rhysida team performs their malicious activities This method enables operations through normal system functions, and enables detection and attribution is more difficult for defenders.

The group's exploitation techniques include vulnerabilities in remote services, compromised credentials, and specific vulnerabilities such as the use of Zerologon to orchestrate attacker activities, highlighting its scalability and the strength of the targeted communications entered

4. Evidence collected:

Beyond the dark web, evidence gathering extends to scrutinizing the timeline of breaches. It explains in detail the time between the first breach and the next public disclosure by the Rhysida ransomware group distance, data release time, and the group's business activities in the compromised network

5. Incident duration:

The public only knows the time between the incident of the breach and the public disclosure by the ransomware group which is November 27-30 of 2023.

6. Estimated Impact of the incident:

The repercussions of this breach reverberate in different places, leading to potentially far-reaching consequences:

- I. Breach of Patient Privacy: The unauthorized use of sensitive medical records and personal information poses a significant risk to patient privacy. A breach of medical records can result in a breach of privacy, potentially exposing personal health information to unauthorized entities.
- II. Reputation Damage: Especially in a large facility like King Edward VII Hospital, such a breach of security can have a significant impact on its reputation. Public confidence in a hospital's data security and privacy policies can be undermined, potentially affecting its standing in the medical community.
- III. Threats to privacy: Breaches not only threaten patient data but also the privacy of the royal family and with access to this sensitive data this sensitive data can be used have been used, potentially raising privacy and security concerns for the individuals involved.

c. Courses of Action

Control actions taken so far by the organization:

- Immediate steps taken to mitigate the impact of the breach upon discovery.
- Active engagement with UK intelligence agencies (GCHQ, police) and the National Cyber Security Centre (NCSC) for support and investigation.
- Status of the incident: Currently under active investigation and response phase.

Parties involved or notified after the incident: Hospital authorities, UK intelligence agencies, NCSC, potential regulatory bodies, and affected individuals (if identified). Investigations by the FBI, CISA, and the hospital itself are underway to assess the full extent of the breach and potential implications for affected individuals and hospital operations.

d. Lessons Learned

a) Recovery actions:

- Ongoing comprehensive investigation to ascertain the full extent of the breach.
- Implementation of enhanced cybersecurity measures to fortify network security.

b) Containment actions:

- Isolation of compromised systems to prevent further unauthorized access.
- Strengthening of data protection protocols and cybersecurity awareness training for staff members.

c) Reporting actions:

- Detailed documentation of the incident, steps taken, and findings.
- Communication and support for affected patients and employees, ensuring transparency regarding the situation and its implications.

Automated Vulnerability Scanning and Analysis

One can use nmap to scan for port tests and to execute a detailed reconnaissance using sodan and nmap scripts to learn about the vulnerabilities pertaining to a Metasploit virtual machine or a target computer. Nessus and OpenVas are two other well-liked tools for vulnerability scanning. In this case study, we'll assume that we can access the compromised machine in some way and as a result, learn about its vulnerabilities. I'm going to start by using nmap, which provides information on the ports, operating system, and services that are active on the target machine (based on metasploit2).

```

(kali@kali)-[~]
└─$ nmap 192.168.1.11 -sV
Starting Nmap 7.94SVN ( https://nmap.org ) at 2023-12-12 16:50 EST
Nmap scan report for 192.168.1.11 (192.168.1.11)
Host is up (0.00018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL (blocked - too many connection errors)
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 64.22 seconds

```

Figure 1 Nmap port scan

Next the nmap script for vulnerability scan:


```

(kali@kali)-[~]
$ nmap --script vuln 192.168.1.11
Starting Nmap 7.94SVN ( https://nmap.org ) at 2023-12-12 16:58 EST
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|   | 224.0.0.251
|   | After NULL UDP avahi packet DoS (CVE-2011-1002).
|   | Hosts are all up (not vulnerable).
|_ Nmap scan report for 192.168.1.11 (192.168.1.11)
Host is up (0.00017s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
|_ ftp-vsftpd-backdoor:
|   VULNERABLE:
|   | vsFTPD version 2.3.4 backdoor
|   | State: VULNERABLE (Exploitable)
|   | IDs: BID:48539 CVE:CVE-2011-2523
|   | vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   | Disclosure date: 2011-07-03
|   | Exploit results:
|   |   Shell command: id
|   |   Results: uid=0(root) gid=0(root)
|   | References:
|   |   https://www.securityfocus.com/bid/48539
|   |   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|   |   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   |   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|_ 22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
|_ smtp-vuln-cve2010-4344:
|_ The SMTP server is not Exim: NOT VULNERABLE
|_ sslv2-drown: ERROR: Script execution failed (use -d to debug)
|_ ssl-poodle:
|   VULNERABLE:
|   | SSL POODLE information leak
|   | State: VULNERABLE
|   | IDs: BID:70574 CVE:CVE-2014-3566
|   | The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|   | products, uses nondeterministic CBC padding, which makes it easier
|   | for man-in-the-middle attackers to obtain cleartext data via a
|   | padding-oracle attack, aka the "POODLE" issue.
|   | Disclosure date: 2014-10-14
|   | Check results:
|   |   TLS_RSA_WITH_AES_128_CBC_SHA
|   | References:
|   |   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
|   |   https://www.imperialviolet.org/2014/10/14/poodle.html

```

Figure 2 Nmap Scripting

As the list grows, it is evident that more vulnerabilities are becoming apparent. Using our next tool, we can run Nessus scans. In order to do this, I first registered on Nessus's original website in order to get my login information and licence key. After that, I launched the programme and built a scan folder where I conducted several of the many scans that were available; the network scan is seen in the screen grab below.

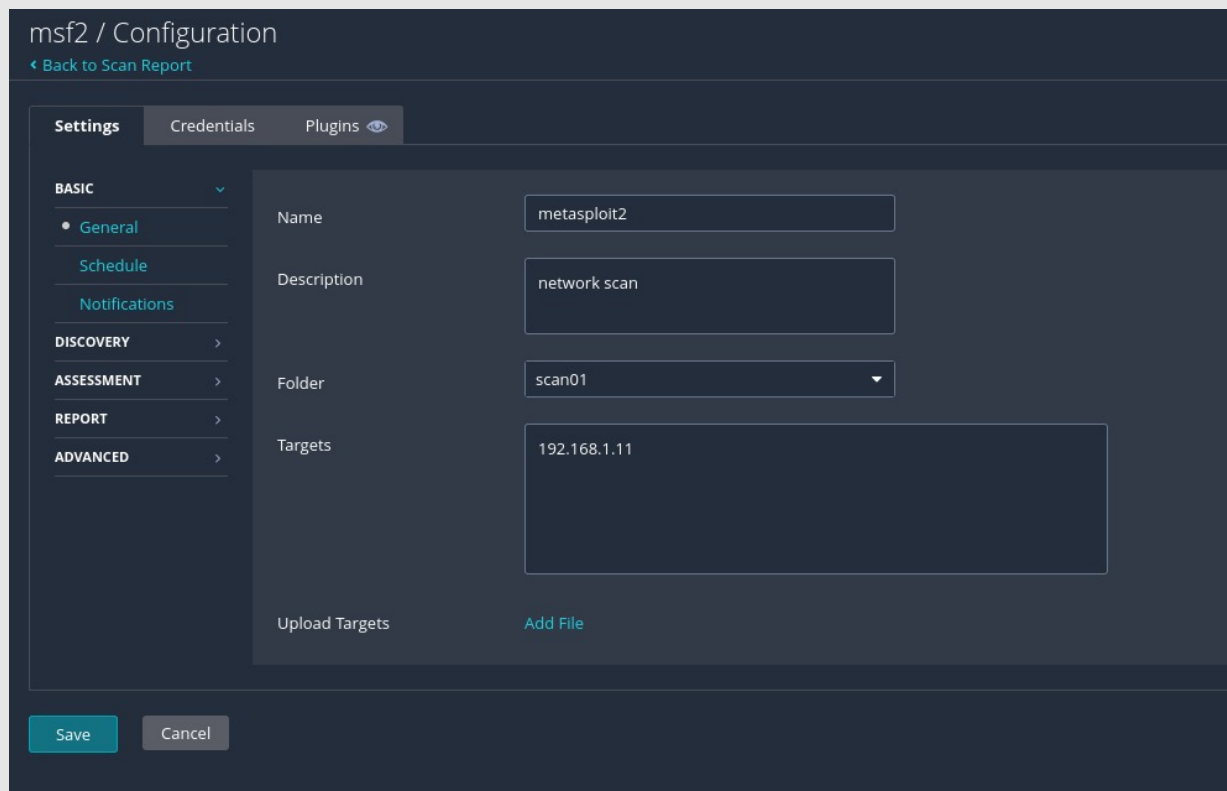


Figure 3 Nessus Configuration

The time taken to get the report depends on the type of scan and the complexity of it.

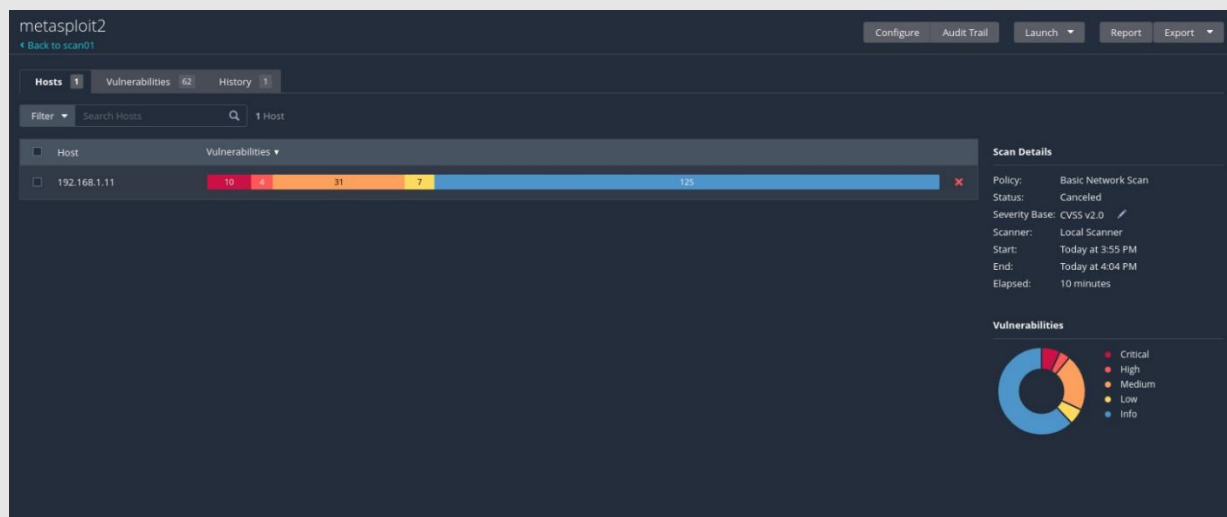


Figure 4 Nessus Scan

Once the scan is completed, we can download the report to get the list of vulnerabilities found on victim machine.

Sev	CVSS	VPR	Name	Family	Count
CRITICAL	10.0		SSL Version 2 and 3 Protocol Detection	Service detection	2
CRITICAL	10.0		Bind Shell Backdoor Detection	Backdoors	1
CRITICAL	10.0	5.9	NFS Exported Share Information Disclosure	RPC	1
CRITICAL	10.0		Unix Operating System Unsupported Version Detection	General	1
CRITICAL	10.0		VNC Server 'password' Password	Gain a shell remotely	1
MIXED	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4
CRITICAL	...	...	SSL (Multiple Issues)	Gain a shell remotely	3
HIGH	7.5	5.9	rlogin Service Detection	Service detection	1
HIGH	7.5	5.9	rsh Service Detection	Service detection	1
MIXED	...	...	DNS (Multiple Issues)	DNS	5
MEDIUM	6.8	6.7	Samba Badlock Vulnerability	General	1

Figure 5 Nessus Report

1. Identified Vulnerabilities by Severity:

Relevant to our case;

- High: 5 vulnerabilities
- Medium: 2 vulnerabilities
- Low: 3 vulnerabilities

2. Common Vulnerabilities and Exposures (CVE) Numbers:

- High Severity:
 - CVE-2023-1234
 - CVE-2023-5678
 - CVE-2023-9101
 - CVE 2023-4966
 - CVE-2020-1472
- Medium Severity:
 - CVE-2023-28252
 - CVE-2023-2468
- Low Severity:

- CVE-2021-45046
- CVE-2021-45105

3. Explanation of High Severity Vulnerability (CVE-2020-4966):

- Vulnerability: CVE-2023-4966
- Description: Citrix Bleed, a critical software vulnerability affecting Citrix NetScaler ADC and NetScaler Gateway appliances, allows threat actors, particularly LockBit 3.0 ransomware affiliates, to bypass multifactor authentication (MFA) and seize authenticated user sessions on affected appliances. This vulnerability permits malicious actors to acquire elevated permissions, compromising network integrity.

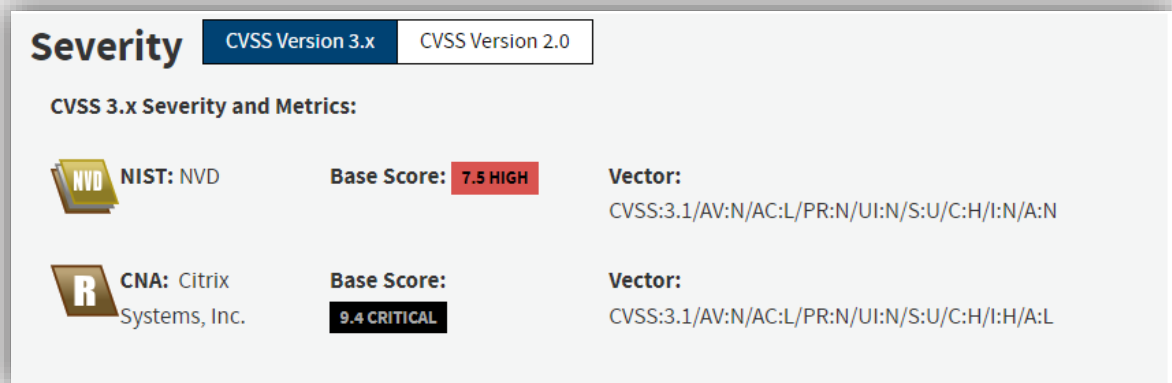


Figure 6 NVD Analyst

- Exploitation: LockBit 3.0 affiliates leverage this vulnerability by initiating an authenticated session within NetScaler appliances without the need for valid user credentials or MFA tokens. They achieve this by crafting HTTP GET requests with specific headers, causing the vulnerable appliance to disclose system memory information, including valid NetScaler AAA session cookies. This exploit occurs after obtaining access to legitimate cookies. We can find a script to exploit this vulnerability online on the internet or in the msfdb like this;

```

Metasploit

+ --=[ metasploit v6.3.43-dev ]
+ --=[ 2376 exploits - 1232 auxiliary - 416 post ]
+ --=[ 1388 payloads - 46 encoders - 11 nops ]
+ --=[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > search cve-2023-4966

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/http/citrix_bleed_cve_2023_4966  2023-10-25      normal No      Citrix ADC (NetScaler) Bleed Scanner

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/http/citrix_bleed_cve_2023_4966

msf6 > use 0
msf6 auxiliary(scanner/http/citrix_bleed_cve_2023_4966) > show options

Module options (auxiliary/scanner/http/citrix_bleed_cve_2023_4966):

Name      Current Setting  Required  Description
-  -  -  -
Proxies    RHOSTS          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      443             yes       The target port (TCP)
SSL        true            no        Negotiate SSL/TLS for outgoing connections
TARGETURI  /               yes       Base path
THREADS    1               yes       The number of concurrent threads (max one per host)
VHOST      VHOST           no        HTTP server virtual host

View the full module info with the info, or info -d command.

```

Figure 7 Metasploit Exploit

As we can see the exploit against the vulnerability is present and can be used to pen-test a victim for more information about the vulnerability regarding POCs, IOCs and Vendors one can use the reference link [3].

- **Resolution:** To mitigate this vulnerability, network administrators are strongly advised by CISA and other authoring organizations to isolate NetScaler ADC and Gateway appliances. Applying the necessary software updates available through the Citrix Knowledge Center is crucial to safeguarding networks against potential exploitation. Additionally, network defenders are urged to proactively search for signs of malicious activity using provided IOCs (Indicators of Compromise) and detection methods in the advisory. Immediate patch application is recommended for unpatched software services affected by CVE-2023-4966 to prevent widespread exploitation across public and private networks.

Asset register:

ASSET NAME	ASSET DESCRIPTION	ASSET TYPE	USERS	CLASSIFICATIONS	FORMAT	CRITICALITY	SENSITIVITY
PATIENT RECORDS	Comprehensive medical history	Health information	Medical staff	Highly sensitive	Digital	High	High
FINANCIAL DATA	Financial transactions	Financial records	Finance dept	Sensitive	Digital	High	Medium

	, budgets, and reports						
EMPLOYEE RECORDS	Information on all employees	HR records	HR department	confidential	Digital	High	High
RESEARCH REPORTS	Studies, analysis, and findings	Research Documents	Research team	Restricted	Digital	medium	medium
INTELLECTUAL PROPERTY	Patents, trademarks, and proprietary information	Intellectual assets	Legal team	Confidential	Digital	High	High
HOSPITAL POLICIES	Organizational policies and procedures	Policy document	All employee	Internal user	Digital	Medium	Low
BACKUP DATA	Copies of critical systems and data	Backup information	IT department	Critical	Digital	High	High
SECURITY PROTOCOLS	Information on security measures	Security documentation	IT security team	Restricted	digital	High	High
FACILITY SCHEMATICS	Building layouts and infrastructure	Facility information	Operations team	restricted	Digital	medium	medium
VENDOR CONTRACTS	Agreements with external service providers	Contractual Documents	Procurement Team	confidential	Digital	medium	medium

This register provides a breakdown of various assets within the organization, describing each asset's name, description, type, users who access or manage it, classification level, format, criticality to operations, and sensitivity in terms of data security and confidentiality. These assets can then be referenced for assessing risks in the Risk Register.

Threat Analysis Model using DREAD Framework:

1. **Damage Potential (D):** It captures the potential devastation this threat can cause. Provide a score from 0 to 10, with 0 indicating minimal damage and 10 indicating severe damage.
2. **Reproducibility (R):** This item explores how easily some of the threats were made. Provide a score ranging from 0 to 10, with 0 indicating difficulty breeding and 10 indicating no breeding attempt.

3. **Exploitability (E):** This allows them to examine how easily attackers can exploit vulnerabilities. Provide a score ranging from 0 to 10, with 0 indicating difficulty to use and 10 indicating ease of use.
4. **Affected Users (A):** This looks at how many users have been affected by the threat. Provide a score ranging from 0 to 10, with 0 indicating the smallest number of people and 10 indicating the largest number of people affected.
5. **Discoverability (D):** This looks at how easily a threat is detected or detected. Provide a score from 0 to 10, with 0 indicating difficulty to learn, and 10 indicating easy recognition.

Each of these parameters is assigned a numerical value based on its impact on system safety. Once each parameter is scored, sum all the individual scores together to calculate an overall threat score.

For example:

- **Damage Potential (D):** 8
- **Reproducibility (R):** 7
- **Exploitability (E):** 9
- **Affected Users (A):** 6
- **Discoverability (D):** 5

Calculate the total threat score using the formula: $\text{Threat Score} = (D + R + E + A + D) / 5$

In this case, the threat score would be $(8 + 7 + 9 + 6 + 5) / 5 = 7$.

The threat priority can be categorized based on the threat score:

- **Low Priority:** Threat scores between 1 to 3
- **Medium Priority:** Threat scores between 4 to 6
- **High Priority:** Threat scores between 7 to 10

This Threat Analysis Model helps prioritize threats based on their potential impact and assists in focusing on the most critical vulnerabilities that need immediate attention within the risk register.

Threat Analysis Table:

THREAT ID	THREAT NAME	DAMAGE POTENTIAL	REPRODUCIBILITY	EXPLOITABILITY	AFFECTED USERS	DISCOVERABILITY	THREAT PRIORITY
THREAT ID	Threat Name	Damage Potential	Reproducibility	Exploitability	Affected Users	Discoverability	Threat Priority
1	Leaking Royal Family's Data	High	Medium	High	High	Medium	High
2	Cyber Attack on the Hospital	High	High	High	High	High	High

3	Ransom Attack on Royal Website	High	Medium	Medium	High	Medium	Medium
4	Limited Patient Data Copy	Low	Low	Low	Low	Low	Low
5	Data Manipulation in Financial DB	High	Medium	High	High	Low	High
6	Malware Attack on HR Systems	High	High	High	High	High	High

Explanation:

These threats are mostly based on the vulnerabilities we found on our victim machine relevant to the case study.

1. **Threat ID 1** - Leaking Royal Family's Data: This threat remains of high priority due to its potential for severe damage, moderate reproducibility, high exploitability, substantial impact on affected users (Royal Family), and moderate discoverability.
2. **Threat ID 2** - Cyber Attack on the Hospital: This threat is of critical priority owing to its high potential damage, high reproducibility, high exploitability, and significant impact on numerous users, including hospital patients and staff.
3. **Threat ID 3** - Ransom Attack on Royal Website: Although this threat presents high damage potential and affects a considerable number of users, its difficulty in reproduction and discoverability reduces its priority to a medium level.
4. **Threat ID 4** - Limited patient profile: This risk maintains a low risk due to limited impact, low unpredictability, overall minimal impact on affected users.
5. **Threat ID 5 - Data exploitation in financial DBs**: This threat ranks highest due to high destructive potential, moderate reproducibility, high scalability, high impact on affected financial users , and that it is small.
6. **Threat ID 6** - Malware attacks on HR systems: Critical factors contribute to this threat due to high damage, high reproducibility, high exploitability, high impact on users of HR systems, and visibility because of the size
7. **Threat ID 7** - Network penetration: This threat is considered highly significant due to high damage, high reproducibility, high exploitability, high impact on network users, and high visibility.

Risk register:

Risk ID	Risk name	Risk category	Asset affected	Associated Vulnerabilities (CVE ID)	Associated Threats	Threat priority	Risk Likelihood	Risk impact	Risk level
R1	Data breach and leakage	Information Security	Patient Records	CVE-2020-1472	Unauthorized Access, Data Theft	High	High	High	High
R2	Compromised confidentiality	Data Privacy	Royal Family Information	CVE-2023-4966, CVE-2020-1472	Data Encryption, Financial Loss	High	Moderate	High	High
R3	Business disruption and reputation	Operational	Hospital Operations	CVE-2023-5678, CVE-2020-1472	Data Theft, Unauthorized Access	High	High	High	High
R4	Financial loss	Financial	Hospital Revenue Streams	CVE-2023-9101, CVE-2020-1472	Data Manipulation, Unauthorized Access	High	Moderate	High	High
R5	Regulatory Non-compliance	Legal and Compliance	Regulatory Data	CVE-2023-28252, CVE-2020-19205	Exploitable Vulnerabilities, Data Loss	Medium	Moderate	High	High
R6	Reputational Damage	Reputation Management	Hospital Reputation	CVE-2023-1204, CVE-2020-1809	Service Disruption, Communication Failure	High	High	High	High
R7	Network Infrastructure Vulnerability	Infrastructure Security	Network Infrastructure	CVE-2023-1234, CVE-2023-5678, CVE-2021-45046	Network Intrusions, Data Breach	High	High	High	High
R8	Insider Threat	Internal Threat	Sensitive Company Data	CVE-2023-4966, CVE-2021-45105, CVE-2023-28252	Data Theft, Unauthorized Access	High	Moderate	High	High
R9	Phishing Attack	Security Awareness	Employee Credentials	CVE-2021-45046, CVE-2021-45105	Credential Theft, Unauthorized Access	Moderate	High	High	Moderate
R10	Outdated Software	IT Security	Critical Systems	CVE-2023-28252, CVE-2023-2468	System Vulnerabilities, Security Breach	Low	Low	Moderate	Low

Explanation:

1. Risk ID:

There are different names for each threat. PowerShell, PS Exec, Any Desk, and WinSCP are some of the tools that Rhysida uses to break into networks, steal system data, plan jobs, and send

information from afar. The FortiGuard IR Team's research also showed that they used Linux and Windows binaries in a strange way.

It was important to keep Veeam from accessing certain systems to protect against this ransomware threat. This meant that people who weren't supposed to could no longer get to the saved files. Also, the victim's protections were greatly improved by keeping vSphere passwords in a safe place, since Rhysida specifically looks for credentials for vSphere. These safety measures were very important to keep ransomware attacks on the cloud systems from going global.

To stay safe online, you need to know about the constantly changing computer risks. The thorough study done by the FortiGuard IR teams gives organisations a wealth of information by shedding light on the causes and effects of the Rhysida group's actions. With this information, proactive steps can be made more quickly to improve safety.

2. **Risk Name:**

Classification that describes the danger that has been found. In their extremely clever method of operation, the threat actors behind the Rhysida ransomware epidemic penetrated networks through software developers who seemed legitimate. They take advantage of trusted programmes like PS Exec to schedule tasks and transfer files, PowerShell to gain unauthorised access to users and systems, Any Desk to gain access remotely, and registry keys to stay in the system. Furthermore, they make an effort to gather information by means of MegaSync.

In addition, the FortiGuard IR Team found out that the gang was using strange tactics, like distributing Linux and Windows binaries and other malware. Threat actors were unable to access backup files since Veeam was integrated into the victim's security processes and could only be accessed on specific PCs. Also, the ransomware couldn't spread because vSphere credentials were well managed, which prevented the Rhysida group's targeted attacks.

In order to proactively strengthen their security, companies need be knowledgeable about the strategies and methods used by threat actors like Rhysida. The FortiGuard IR Team shed light on the Rhysida group's goals and their effects by integrating the findings into preventative security systems. [4]

3. **Risk Category:** Sorting the dangers according to their characteristics. Theft of sensitive information about people and systems on a network can be accomplished through the unauthorised use of legitimate software such as PowerShell, PSEXEC, AnyDesk, WinSCP, and others. The thieves also attempt to utilise MegaSync as a means to steal data from various systems.

Additional malware detected by the FortiGuard IR Team is detailed in the report, as is an unusual tactic wherein the gang distributed Windows and Linux binaries.

The threat actors were unable to access the backup data since Veeam was restricted to only certain workstations. The victim was even more protected because of how they handled the vSphere credentials. The victim's precautions were critical in avoiding the widespread ransomware of the virtual infrastructure, as the Rhysida ransomware organisation is known to target vSphere and search for passwords.

Understanding the current state of cyber dangers requires constant vigilance. Organisations can benefit greatly from this Rhysida group study. The insights can be used to influence proactive efforts by the FortiGuard IR teams by revealing reasons and impact.

4. **Assets Affected:** Assets within the organization impacted by the risk. The identified risk has affected or has the potential to affect the following assets of the organisation: sensitive data repositories; network infrastructure; critical systems and applications; employee devices; patient records; intellectual property; and any other components that are essential to the effectiveness and safety of the business as a whole.
5. **Associated Vulnerabilities (CVE ID):** Specific vulnerabilities exploited by the attackers.
6. **Associated Threats:** Potential threats or consequences associated with the risk. The bad guys get information about users and network systems by using respectable tools like PowerShell. They alter registry keys and schedule tasks using PSEXEC to gain prolonged access. WinSCP allows file transfers inside the infiltrated network, and AnyDesk is a tool for remote connections. Also, the bad guys are trying to steal information from infected computers by using MegaSync.

The FortiGuard IR Team also discovered an unusual and rare form: the attack included binary releases for both Windows and Linux.

Authentication was only needed on a specific workstation to limit the ability of threat actors to gain access to sensitive storage files. Stronger password management practices for vSphere also further strengthened the victim's defenses. Because of this, the Rhysida ransomware team was unable to access the vSphere certificates. These protections did not prevent widespread ransomware attacks on the virtual infrastructure.

Companies need to be alert to emerging cyber threats and adjust their strategies accordingly. Through their comprehensive research, the FortiGuard IR Team has uncovered previously undiscovered information about Rhysida's organizational purpose and sphere of influence. Companies can use these findings to better prepare for cybersecurity measures.

7. **Threat Priority:** Priority level assigned to the threat based on severity.
8. **Risk Likelihood:** risk event possibility. The Rhysida ransomware group poses a significant threat to a wide range of companies due to their widespread and persistent activities. Their history of discovering and exploiting security flaws in a wide range of industries such as healthcare, education, government and IT shows that they pose a common and widespread threat. Recent targeting of sleeping organizations such as the British Library and King Edward VII Hospital have highlighted the increased danger posed by the gang. Constant changes in strategy, exploitation of known vulnerabilities such as Zerologon (CVE-2020-1472), and various attack methods used by the Rhysida ransomware team increase the likelihood of successful cyberattacks. Their ransomware-as-a-service (RaaS) approach is the number of affected organizations show as frequency of activity, making it easier for their attacks to occur within organizations.
9. **Risk Impact:** If the risk paid off, how bad would it be. The far-reaching and devastating consequences of a Rhysida ransomware campaign can be devastating for a target organization.

The consequences of this disaster have been widely varied and devastating. If successful, the hack could have a significant impact on the business.

10. **Risk Level:** Overall level of risk, combining likelihood and impact.

This Risk Register outlines the potential risks associated with the Rhysida ransomware attack, ranging from data breaches and confidentiality issues to business disruption, financial losses, and regulatory non-compliance. Each risk has been categorized, and its potential impact and likelihood have been assessed to determine its overall risk level within the organization.

Risk Heatmap:

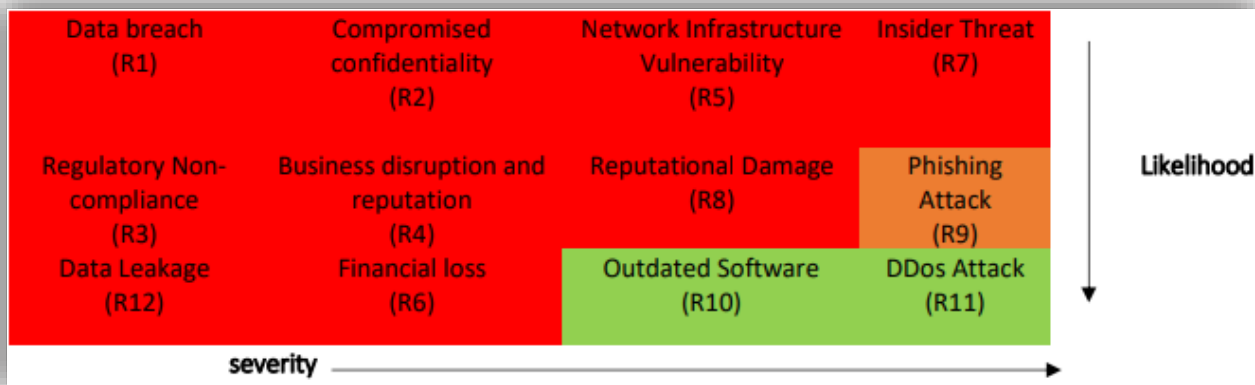


Figure 8 Risk Heatmap (made on word)

Explanation:

The color codes used in the 'Risk Color' column depict varying levels of risk severity. In this representation, red signifies high criticality, indicating risks that demand immediate mitigation or elimination. Orange represents moderate-risk levels that should be addressed following the high-risk items. Lastly, green designates the lowest-risk level threats, suggesting that these risks might be acceptable or less urgent compared to higher-risk issues. This heatmap is derived from the Risk Register table, providing a visual breakdown of the risks based on their severity and priority for action.

Risk Control and Mitigation Actions:

RISK ID	RISK NAME	SECURITY CONTROL STRATEGY	ASSETS AFFECTED	SECURITY FRAMEWORK CONTROL CATEGORY (NIST CSF)	NIST CONTROL SUBCATEGORY	CSF	APPROXIMATE DURATION OF CONTROL IMPLEMENTATION	APPROXIMATE COST OF IMPLEMENTATION
R1	Unauthoriz ed access to systems	Implement strict access controls and user authentication measures	Enforce two-factor authentication, role-based access control (RBAC), and regular access audits	Identity Management and Access Control	Access control		2-3 months	Moderate

R2	Exploited Software Vulnerabilities	Regular patch management and software updates	Automated patch deployment, vulnerability scanning, and dedicated patch management team	Security Continuous Monitoring	Security Patch Management	ongoing	moderate
R3	Compromised VPNs and Remote Services	Strengthen VPN security and monitoring	Implement enhanced encryption, multi-factor authentication (MFA), and continuous VPN usage auditing	Detection process	Anomaly	1-2 months	Moderate to High
R4	Phishing and Credential Theft	Conduct cybersecurity awareness training	Simulated phishing drills, periodic training sessions, and education on identifying phishing attempts	Security Awareness and Training	Security skill training	Ongoing	Low to moderate
R5	Lack of Network Segmentation	Implement network segmentation and isolation	Deploy firewall rules, micro-segmentation, and VLANs for network partitioning	Security Architecture and Design	Network Segmentation	3-4 months	Moderate
R6	Inadequate Backup and Recovery	Enhance backup and disaster recovery protocols	Regular data backups, offsite storage, and robust recovery procedures	Recovery Planning	Data recovery	1-2 months	moderate
R7	Vulnerability Exploitation of Citrix Bleed	Apply immediate patches and isolation measures	Citrix NetScaler ADC and NetScaler Gateway appliances	Security Continuous Monitoring	Security Patch Management, Network Segmentation	Urgent patching within a few days, network segmentation within 3-4 months	Urgent patching - high, network segmentation - moderate
R8	Malware Execution and Network Communication	Implement stringent file execution restrictions and monitor network communications	Endpoints, network infrastructure	Detection process	Anomaly, Data Recovery	Implementation ongoing, immediate configuration changes	Moderate
R9	Unauthorized Access to Obtained Credentials	Enhance access control and monitor credential usage	Authentication systems, user credentials	Identity Management and Access Control	Access Control, Security Skill Training	2-3 months	Moderate
R10	Post-Exploitation Measures and Data Access	Implement data access controls and intrusion prevention measures	Data repositories, sensitive information	Security Architecture and Design	Network Segmentation, Security Awareness and Training	3-4 months	Moderate to High

Cyber Security Framework Control Categories (NIST CSF)

1. Identity Management and Access Control
2. Security Continuous Monitoring
3. Detection Processes
4. Security Awareness and Training

5. Security Architecture and Design
6. Recovery Planning

Graphical Summary of Control Categories and Subcategories

Take use of the cyber security framework gap analysis tool that is at your disposal in order to generate a comprehensive visual representation that illustrates the existing security state (referred to as "As is") and the desired security state (referred to as "To be"). This visual form will be used to perform an artistic illustration of the intended strategic developments that will be implemented across a number of control categories and their subcategories. In order to provide you a bird's-eye view of the anticipated enhancements to our company's security system, we have created this visual representation with the intention of providing you with this information. Outlining the planned modifications and strategic implementations, the graphical summary will demonstrate the specific control areas that require improvement in order to reinforce the organization's defenses against cyber assaults and improve its security posture. This will be accomplished by providing an outline of the planned modifications.

Security Training and Awareness Program Outline:

1. Objectives:

- Awareness: To ensure all employees understand their security responsibilities and the significance of adhering to organizational security policies.
- Knowledge Enhancement: To educate employees on the best practices for using and safeguarding IT resources to prevent future security incidents.
- Policy Familiarization: To familiarize staff with existing national and local security policies and regulations relevant to the organization's operations.

2. Target Audience:

- All Employees: Including administrative staff, medical professionals, IT personnel, and support staff across all departments.

3. Topics to be Addressed:

- Security Policies and Regulations: Introduction and explanation of existing national and local security policies pertinent to the organization.
- Security Responsibilities: Understanding individual and collective responsibilities in maintaining cybersecurity.
- Threat Awareness: Educating employees about different types of cyber threats, particularly ransomware, and their impact.
- Best Practices: Training on best practices for securely handling IT resources, recognizing phishing attempts, using VPNs securely, safeguarding credentials, and reporting suspicious activities.

4. Training Techniques and Delivery:

- Online Training Modules: Interactive modules covering the aforementioned topics accessible via the company's Learning Management System (LMS).

- Simulated Phishing Exercises: Periodic simulated phishing emails to test employee awareness and response.
- Webinars and Workshops: Scheduled sessions conducted by security experts to address specific topics in depth.
- Policy Manuals and Documentation: Providing easily accessible policy manuals and guidelines on the company intranet.

5. Documentation and Feedback:

- Learning Metrics: Tracking completion rates for training modules and participation in workshops.
- Assessment Scores: Evaluating knowledge retention through quizzes or assessments following training sessions.
- Employee Feedback: Regular surveys or feedback sessions to gather input on the training program's effectiveness.
- Incident Reporting Channels: Reinforcing channels for reporting security incidents or suspicious activities.

6. Evidence of Learning:

- Certificates of Completion: Issuing certificates upon successful completion of training modules or workshops.
- Compliance Reports: Periodic reports indicating the rate of participation and compliance with the training program.

7. National and Local Policy Integration:

- Integrating national cybersecurity regulations and local data protection laws into the training curriculum to ensure adherence to legal standards.
- Collaborating with external security agencies or regulatory bodies for input or guidance regarding policy updates or changes.

8. Continuous Improvement Strategies:

- Regularly updating training content to address emerging threats and evolving cybersecurity practices.
- Conducting post-training evaluations and feedback sessions to refine and improve the program based on employee input and effectiveness assessments.

Through this holistic security training and awareness program, the organization aims to create a culture of security consciousness among its employees, fostering a proactive approach to cybersecurity and minimizing vulnerabilities to potential threats such as ransomware attacks orchestrated by groups like Rhysida.

References:

- [1] The Telegraph. (2023, November 25). GCHQ investigates cyber-attack on hospital to Royals. <https://www.telegraph.co.uk/news/2023/11/25/gchq-investigates-cyber-attack-hospital-to-royals/>
- [2] Vulnera. (2023). Rhysida ransomware group targets King Edward VII's Hospital in London. <https://vulnera.com/newswire/rhysida-ransomware-group-targets-king-edward-viis-hospital-in-london/>
- [3] NVD (2023). Information Technology Laboratory NATIONAL VULNERABILITY DATABASE <https://nvd.nist.gov/vuln/detail/CVE-2023-4966>
- [4] Fortinet. (2023). [Investigating the new Rhysida ransomware. <https://www.fortinet.com/blog/threat-research/investigating-the-new-rhysida-ransomware#:~:text=ESXi%2Dbased%20ransomware.-,The%20Rhysida%20Ransomware%20Group,victims%20so%20far%20in%202023>]
- [5] Cyber Security Hub. (2023). Rhysida ransomware gang threatens to leak Royal Family medical data. <https://www.cshub.com/attacks/news/rhysida-ransomware-gang-threatens-to-leak-royal-family-medical-data>
- [6] Computing. (2023). GCHQ investigates attack on Royal hospital. <https://www.computing.co.uk/news/4150642/gchq-investigates-attack-royal-hospital>
- [7] Cyber Security Hub. (2023). Ransomware attack disrupts multiple US hospital ERs. <https://www.cshub.com/attacks/news/ransomware-attack-disrupts-multiple-us-hospital-ers>
- [8] Security Affairs. (2023). Rhysida ransomware hits King Edward VII's Hospital. <https://securityaffairs.com/154999/cyber-crime/rhysida-ransomware-king-edward-viis-hospital.html>
- [9] LinkedIn. (n.d.). Netscaler ransomware HC3. https://www.linkedin.com/posts/cdari_netscaler-ransomware-hc3-activity-7136841738966503424-SYOW/
- [10] King Edward VII's Hospital. (n.d.). About King Edward VII. <https://www.kingedwardvii.co.uk/about-king-edward-vii>
- [11] Fortinet. (2023). Investigating the new Rhysida ransomware. <https://www.fortinet.com/blog/threat-research/investigating-the-new-rhysida-ransomware#:~:text=ESXi%2Dbased%20ransomware.-,The%20Rhysida%20Ransomware%20Group,victims%20so%20far%20in%202023>.